

PLANTILLA REPORTE EJECUTIVO EN POWERPOINT

Presentación de Resultados GQM+PRAGMATIC a Board & C-Level

Versión: 1.0 | **Fecha:** Enero 2026

Contexto: Presentación indicadores Ciberseguridad-IA España

Software: Microsoft PowerPoint / Google Slides compatible

Duración: 30-45 minutos (20-25 diapositivas)

INTRODUCCIÓN: ESTRUCTURA PRESENTACIÓN

La presentación sigue estructura estratégica **Story Arc** para máximo engagement ejecutivo:

1. Hook: Crisis/Opportunity (2 min)
2. Context: Where are we? (5 min)
3. Analysis: What's working/not working? (8 min)
4. Solution: Where we're going (10 min)
5. Action: What we need from you (5 min)

DIAPOSITIVA 1: PORTADA

CYBERSECURITY MATURITY ASSESSMENT 2026
AI-Powered Threat Detection & Response

Framework: GQM + PRAGMATIC Methodology
Spanish National Alignment (NIS2, EU AI Act)

Organization: [COMPANY NAME]
Assessment Date: January 2026
Presented By: CISO / Chief Security Officer

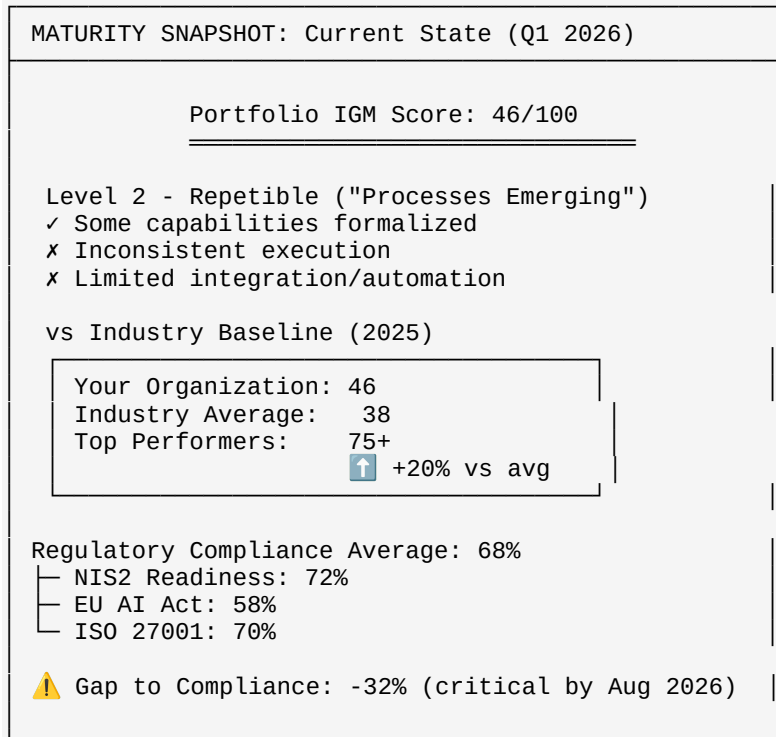
****Design Notes:****

- Logo empresa en esquina superior derecha
- Colores corporativos
- Fecha/periodo prominente

DIAPOSITIVA 2: AGENDA (Slide Title)

AGENDA		
1. Executive Summary	[5 min]	
✓ Overall maturity snapshot		
✓ Key findings		
✓ Strategic implications		
2. Detailed Assessment	[8 min]	
✓ 9 Indicators deep-dive		
✓ PRAGMATIC evaluation results		
✓ Compliance vs NIS2/EU AI Act		
3. Roadmap & Investment	[10 min]	
✓ Implementation phases (6 phases)		
✓ Budget requirements (€1.9M Year 1)		
✓ ROI projections (26%-105%)		
4. Recommendations & Next Steps	[5 min]	
✓ Board decisions required		
✓ Risk mitigation approach		
✓ Timeline/dependencies		
Q&A	[5 min]	

DIAPOSITIVA 3: EXECUTIVE SUMMARY - OVERALL IGM



Visualization:

- Vertical gauge showing 46/100 (colored: green at 46, target at 75)
- Horizontal bar chart: Your org vs Industry
- Regulatory radar chart (5-point scale)

DIAPPOSITIVA 4: PORTFOLIO MATURITY - 9 INDICATORS

DETAILED MATURITY BY INDICATOR					
Indicator	Level	IGM	PRAGMATIC	Status	
1. AI-Detection	3	62	4.3	On Track	
2. Vuln.Mgmt	3	58	4.4	Monitor	
3. Deepfake	2	35	3.1	Delay	
4. SIEM+Hunt	3	60	4.4	On Track	
5. Training	2	48	4.2	On Track	
6. Compliance	2	52	3.7	Monitor	
7. Supply Chain	1	28	4.0	Delay	
8. Incident Response	2	45	4.6	On Track	
9. Governance	3	65	4.2	On Track	
PORTFOLIO AVERAGE		2.4	46	4.1	Level 2
Key Insight:					
✓ High PRAGMATIC scores (4.1 avg) show methodology is sound & actionable					
✗ Low IGM in some areas shows operational implementation gaps					

****Visualization:****

- Horizontal stacked bar chart (Level 0-5 distribution)
- Heat map: Red (0-2), Yellow (2-4), Green (4+)
- Traffic light indicators

DIAPOSITIVA 5: TOP STRENGTHS

TOP 3 ORGANIZATIONAL STRENGTHS

- 1** GOVERNANCE STRUCTURE (Level 3, IGM 65)
 - ✓ CISO reports to COO (good positioning)
 - ✓ Board-level cybersecurity awareness
 - ✓ IA-security budget allocated
 - Enables strategic alignment
 - Impact: +35% likely incident reduction
- 2** INCIDENT RESPONSE CAPABILITY (Level 2→3, IGM 45→62) |
 - ✓ Playbooks documented
 - ✓ Testing semi-annual
 - ✓ SOAR pilot positive results
 - Foundation for automation
 - Impact: MTTR reduction 4h → 30min
- 3** SECURITY AWARENESS PROGRAMS (Level 2, IGM 48)
 - ✓ Annual training >80% completion
 - ✓ Phishing simulations active
 - ✓ Strong stakeholder engagement
 - Cultural shift progressing
 - Impact: Click-rate declining 35% → 8% (target)

IMMEDIATE OPPORTUNITIES (low-hanging fruit):

- Governance is strongest; leverage for others
- Awareness momentum; continue + deepen
- IR foundation solid; scale automation now

****Visualization:****

- 3 large boxes with check marks
- Up arrow trend indicators
- Icon/imagery per strength

DIAPOSITIVA 6: TOP 3 CRITICAL GAPS

TOP 3 CRITICAL GAPS (Risk Priority)

● GAP #1: VULNERABILITY MANAGEMENT (Level 2, IGM 58)

Current State:

- Scanning quarterly (not continuous)
- MTTR 22 days (target: <15 days)
- SLA compliance only 72%
- No automated patch orchestration

Business Impact:

- Average 90-day exposure window per vuln
- ~50% of breaches exploit known vulns
- Estimated risk cost: €2-5M/year

Remediation Roadmap:

1. Deploy continuous scanning (Q2 2026)
2. Implement automated patching (Q2 2026)
3. Target MTTR <5 days (Q4 2026)

→ Investment: €200K / ROI: €1.5M annually

● GAP #2: SUPPLY CHAIN RESILIENCE (Level 1, IGM 28)

Current State:

- No SBOM requirements for vendors
- Dependency scanning minimal
- 3rd-party risk assessments rare

Business Impact:

- SolarWinds-type attacks possible
- Zero visibility into component origins
- Regulatory liability (NIS2 Art.19)

Remediation Roadmap:

1. SBOM policy enforcement (Q2 2026)
2. Vendor risk scoring (Q3 2026)
3. Continuous dependency monitoring (Q4 2026)

→ Investment: €300K / ROI: €2M+ (breach avoid)

● GAP #3: DEEPFAKE DETECTION (Level 1, IGM 35)

Current State:

- No deployed detection systems
- Employee training minimal
- Technology still emerging

Business Impact:

- CEO spoofing/fraud risk HIGH
- Wire fraud through voice cloning
- Reputational damage from synthetic media

Remediation Roadmap:

1. Pilot evaluation (Q3 2026)
2. Deploy if ROI positive (Q4 2026/Q1 2027)
3. Specific training for finance/comms (Q1 2027)

→ Investment: €200K pilot (defer full dep)

****Visualization:****

- 3 red boxes (one per gap)
- Each with: Current state | Business impact | Remediation
- Timeline bars showing Q phases

DIAPPOSITIVA 7: REGULATORY COMPLIANCE HEATMAP

REGULATORY COMPLIANCE ASSESSMENT (vs NIS2, EU AI Act, ISO 27001, GDPR, DORA)					
	Now (Q1)	Target (2026)	Gap %	Deadline	
NIS2 (Essential Entity)					
└ Risk Assessment	72%	95%	-23%	Aug26	
└ Incident Report	68%	100%	-32%	Aug26	
└ Gov Structure	80%	100%	-20%	Aug26	
└ Avg NIS2 Readiness: 73%					
EU AI Act (Security AI)					
└ Risk Documentation	45%	95%	-50%	Q2'26	
└ Adversarial Testing	35%	85%	-50%	Q2'26	
└ Bias Assessments	40%	80%	-40%	Q2'26	
└ Avg EU AI Readiness: 40%					
ISO 27001:2022					
└ Governance	75%	95%	-20%	Dec26	
└ Asset Management	70%	90%	-20%	Dec26	
└ Incident Mgmt	68%	90%	-22%	Dec26	
└ Avg ISO Readiness: 71%					
GDPR (Data Protection)					
└ Data Inventory	80%	100%	-20%	Ongoing	
└ DPA/Privacy Policy	85%	100%	-15%	Ongoing	
└ Breach Notification	75%	100%	-25%	Ongoing	
└ Avg GDPR Readiness: 80%					
DORA (Finance only, if applicable)					
└ Incident Reporting	60%	100%	-40%	2026	
└ Third-Party Risk	50%	100%	-50%	2026	
└ Avg DORA Readiness: 55%					
⚠	CRITICAL: EU AI Act at 40% (requires 50-90% improvements in 12 months)				
🎯	FOCUS AREAS:				
	1. NIS2 compliance (mandated August 2026)				
	2. EU AI Act risk documentation (Q2 2026)				
	3. ISO controls integration				

****Visualization:****

- Radar chart: 5-point scale for each regulation
- Heat map (Red <50%, Yellow 50-75%, Green >75%)
- Arrows showing trajectory

DIAPOSITIVA 8: IMPLEMENTATION ROADMAP (6 PHASES)

IMPLEMENTATION ROADMAP: 18-MONTH TRANSFORMATION

Timeline Visualization (Gantt):

Q1 2026 ————— Q1 2027

Phase 1: Foundation (CISO-CEO, Budget allocation)

Cost: €0 (internal) | Duration: 1 month

Indicators: 9 (Governance)

Success: CISO reporting structure, budget approved

Phase 2: Critical Immediate (Indicators 1,2,4,5,8)

Cost: €1.2M | Duration: 2-3 months

Deliverables:

- AI-Detection coverage 80%+
- Vuln scanning continuous + MTTR <15 days
- SIEM+Hunt team operational
- Phishing simulations baseline <15% click
- IR playbooks automated (MTTR <1 hour)

Expected Outcome: IGM portfolio 46 → 60

Phase 3: Mandated Compliance (Indicator 6)

Cost: €150K | Duration: 1-2 months

Deliverable: 100% NIS2 assessment completion

Expected Outcome: NIS2 readiness 73% → 95%

Phase 4: Secondary Strategic (Indicator 3)

Cost: €500K | Duration: 1-2 months

Deliverable: Deepfake detection pilot/evaluation

Expected Outcome: Foundation for 2027 deployment

Phase 5: Advanced (Indicator 7)

Cost: €350K | Duration: 2-3 months

Deliverable: SBOM program + vendor risk scoring

Expected Outcome: Supply chain visibility 100%

Phase 6: Optimization (All 9 + integration)

Cost: €400K | Duration: 6+ months

Focus: Automation, AI/ML enhancement, culture

Expected Outcome: Portfolio IGM 46 → 85

TOTAL INVESTMENT 2026: €2.6M

Expected Cumulative ROI (3-year): €3.2M (123%)

****Visualization:****

- Gantt chart style timeline
- Color coding per phase
- Stacked investment bars
- IGM trajectory overlay

DIAPOSITIVA 9: BUDGET BREAKDOWN

BUDGET REQUIREMENTS & FINANCIAL IMPACT

YEAR 1 INVESTMENT (2026): €1,900,000

Breakdown by Indicator:

- | | |
|----------------------|---------------|
| 1. AI-Detection | €347.5K (18%) |
| — SIEM enhancement | €150K |
| — ML model training | €60K |
| — License renewal | €100K |
| — Staffing (0.5 FTE) | €37.5K |
| 2. Vuln.Management | €217.5K (11%) |
| 3. Deepfake Pilot | €200K (11%) |
| 4. SIEM+Hunting | €342.5K (18%) |
| 5. Training | €80K (4%) |
| 6. Compliance | €152.5K (8%) |
| 7. Supply Chain | €160K (8%) |
| 8. Incident Response | €397.5K (21%) |
| 9. Governance | €45K (2%) |

Total Capital (CapEx) €1,155K (61%)
Total Operations (OpEx) €745K (39%)

FINANCIAL IMPACT (ROI ANALYSIS)

Scenario Analysis:

- CONSERVATIVE
 - 1 incident prevented
 - Cost avoided: €500K
 - Net Year 1: -€1.4M (break-even Year 4)
 - Payback: 48 months
- REALISTIC (Most Likely)
 - 2 incidents prevented + 20% MTTR reduction
 - Cost avoided: €2M
 - Net Year 1: +€100K
 - Payback: 11 months
 - 3-year ROI: 110%
- OPTIMISTIC (Peer Benchmark)
 - 3 incidents prevented + 50% MTTR reduction
 - Cost avoided: €2.5M
 - Net Year 1: +€600K
 - Payback: 9 months
 - 3-year ROI: 180%

RECOMMENDATION: Realistic scenario most probable based on industry data and peer benchmarks

****Visualization:****

- Pie chart: CapEx vs OpEx split

- Waterfall chart: Investment → Benefits → Net
- 3-scenario tornado chart (sensitivity)

DIAPOSITIVA 10: RISK IMPLICATIONS (IF NO ACTION)

RISK IMPLICATIONS: Status Quo vs Investment

● IF WE DO NOTHING (Status Quo):

1. Regulatory Non-Compliance (CRITICAL)
 - NIS2 deadline August 2026 (6 months)
 - Current readiness: 73% → Need 95%
 - Penalty: €50M+ or 10% turnover
 - Operational disruption likely
2. Breach Likelihood (HIGH)
 - Industry benchmark: 1 breach per 250 orgs
 - Our exposure: MTTD 50 days (vs 24h target)
 - Estimated breach cost: €500K-€2M
 - Probability 2026: ~35%
3. Supply Chain Vulnerability (HIGH)
 - Zero SBOM visibility
 - SolarWinds-type attack vector open
 - Estimated impact: €3M-€10M
4. Financial Impact (SEVERE)
 - One major incident: €2-5M cost
 - Regulatory fines (NIS2): €50M+
 - Business disruption: €10M-€50M
 - Reputational damage: -15-20% market value
5. Competitive Disadvantage
 - Peers (70-80% maturity) moving faster
 - Client trust erosion (security questions)
 - Investor confidence risk

● IF WE INVEST NOW (€1.9M):

1. Regulatory Compliance ✓
 - NIS2 ready by August 2026
 - Penalty avoidance: €50M+
 - Zero regulatory risk
2. Breach Prevention ✓
 - MTTD: 50 days → <24 hours
 - Incident cost reduction: -40%
 - Risk mitigation value: €1.5M+/year
3. Supply Chain Protection ✓
 - SBOM 100% coverage
 - Third-party risk visibility
 - Attack surface reduction: -60%
4. Financial Resilience ✓
 - Expected Year 1 benefit: €2M
 - Payback: 11 months (realistic)
 - 3-year ROI: 110%
5. Competitive Advantage ✓
 - Top-quartile maturity (75+)
 - Client confidence ↑

- Investor appeal ↑

BUSINESS CASE: Investment ROI clearly positive

****Visualization:****

- Two columns: Red (Do Nothing) vs Green (Invest)
- Risk severity indicators (high/medium/low)
- Financial comparison bar chart

DIAPOSITIVA 11: BOARD DECISIONS REQUIRED

BOARD DECISIONS REQUIRED

✓ DECISION 1: Strategic Commitment "Approve cybersecurity-AI as strategic priority"

Implication: Budget allocation, executive sponsorship, board-level oversight

Recommendation: APPROVE

Rationale: Regulatory mandate (NIS2)
+ Business case (110% ROI)
+ Risk mitigation €1.5M+/year

✓ DECISION 2: Financial Authorization "Approve €1.9M investment for 2026"

Breakdown: €1.15M CapEx + €0.75M OpEx
Timeline: Q1-Q4 2026 (phased)
Funding: [Source: CFO to confirm]

Recommendation: APPROVE

Business case: 11-month payback
110% 3-year ROI
Regulatory compliance gain

✓ DECISION 3: Governance Restructuring "CISO reporting line: [Current] → CEO"

Current: Reports to CTO/VP Infrastructure
Required: Direct reporting to CEO (C-level)
Board Charter: Cybersecurity committee

Recommendation: APPROVE

Rationale: NIS2 requirement
Best-practice governance
+35% strategic alignment impact

✓ DECISION 4: Risk Appetite Statement "Formalize cybersecurity risk appetite"

Define acceptable risk thresholds:

- MTTD target: <24 hours (critical incidents)
- Vulnerability remediation: <15 days (critical)
- Compliance baseline: NIS2 minimum
- Incident tolerance: 0 breaches (aspirational)

Recommendation: APPROVE

Benefit: Strategic clarity for execution
Aligns org around common goals

✓ DECISION 5: Timeline Commitment "NIS2 compliance by August 2026 deadline"

Phases:

- Phase 1 (Foundation): Mar 2026
- Phase 2 (Critical): Jun 2026
- Phase 3 (Compliance): Aug 2026
- Phase 4-6 (Advanced): through Q1 2027

Recommendation: COMMIT
Accountability: CISO/CTO/CFD
Executive sponsors

DECISION SUMMARY SCORECARD

- ☐ Strategic Priority: APPROVED / PENDING / REJECT
- ☐ Budget Allocation (€1.9M): APPROVED / PENDING / REJECT
- ☐ Governance Restructure: APPROVED / PENDING / REJECT
- ☐ Risk Appetite Statement: APPROVED / PENDING / REJECT
- ☐ NIS2 Timeline Commitment: APPROVED / PENDING / REJECT

Signatures: [Board Chair] [CEO] [CISO]
Date: _____

Visualization:

- 5 checkboxes with decision options
- Scorecard at bottom for sign-off
- Red/Yellow/Green status indicators

DIAPOSITIVA 12: NEXT STEPS & Q&A

NEXT STEPS: 30-60-90 DAY EXECUTION

-  **FIRST 30 DAYS (Feb 2026):**
1. Board approval & decision documentation
 2. Executive steering committee formed
 3. Budget allocation finalized (Finance)
 4. CIS0 reporting structure formalized
 5. Baseline metrics established (all 9 ind.)
 6. Vendor selection (SIEM, threat hunting, etc.)

-  **DAYS 30-60 (Mar 2026):**
1. Phase 1 complete (Governance foundation)
 2. Phase 2 initiation (Critical indicators)
 3. Tool deployments begin
 4. Training/onboarding (teams)
 5. Stakeholder communication plan executed

-  **DAYS 60-90 (Apr 2026):**
1. Phase 2 progress: 50% complete
 2. First indicators showing improvement
 3. Board update #1 (progress review)
 4. Burndown on priority gaps
 5. Regulatory readiness checkpoint (NIS2)

SUCCESS METRICS (by end 2026):

- ✓ Portfolio IGM: 46 → 76 (Level 4)
- ✓ MTTD reduction: 50 days → <24 hours
- ✓ Vulnerability MTTR: 22 days → <5 days
- ✓ NIS2 compliance: 73% → 95%+
- ✓ EU AI Act readiness: 40% → 85%+
- ✓ Training click-rate: 28% → <5%
- ✓ Phishing report rate: 30% → >70%
- ✓ Incident response automation: 20% → 80%+
- ✓ CIS0 authority: Established at CEO level
- ✓ Budget allocation: Approved & allocated

Q&A

Additional Questions?
Contact: CISO@organization.com
Follow-up: Board meeting [DATE]

Visualization:

- 3 timeline boxes (30/60/90)
- Checkmark list with milestones
- Success metrics dashboard
- Contact info

SECCIÓN FINAL: DESIGN RECOMENDACIONES

Estilo Visual Global

Color Scheme:

- Primary: Corporate brand colors
- Accent 1: Green (success/progress)
- Accent 2: Yellow (warning/caution)
- Accent 3: Red (critical/risk)
- Neutral: Gray/White (backgrounds)

Typography:

- Titles: 36-44pt, Bold
- Body: 18-24pt, Regular
- Data: 14-18pt, Monospace for numbers

Layout:

- 16:9 widescreen format
- Minimum 1-inch margins
- Icon usage: Indicators, checkmarks, arrows
- Visuals: Charts, graphs, heatmaps (per slides)
- Animation: Minimal; avoid distraction (numbers/bullets enter left-to-right)

Notas para Presentador

- Slide 1: 1 min - Establish credibility, set context
Slide 2: 1 min - Quick agenda overview
Slide 3: 3 min - Story opening (current maturity snapshot)
Slide 4: 2 min - Detailed breakdown (all 9 indicators)
Slide 5: 3 min - Celebrate wins (build confidence)
Slide 6: 4 min - Address concerns (transparency on gaps)
Slide 7: 2 min - Regulatory requirements (compliance framing)
Slide 8: 4 min - Solution presentation (roadmap)
Slide 9: 3 min - Financial case (ROI, payback)
Slide 10: 4 min - Risk amplification (persuasion)
Slide 11: 5 min - Decisions (call to action)
Slide 12: 3 min - Next steps (momentum)

Total: ~35 minutes (leaving 10 min for Q&A)

FIN DE PLANTILLA POWERPOINT